

Data Governance Policy — Spotify

Politique de gouvernance des données

Emeline ROBLOT — Data Governance Specialist

Septembre 2026

Owner	Approbation	Version	Date d'effet	Revue
Chief Data Officer	Data Governance Committee, avis DPO et Legal	1.0	M1 du plan d'implémentation	Annuelle, ou à tout changement réglementaire majeur

1. Objet et champ d'application

Objet. Cette politique définit comment Spotify gouverne ses données pour atteindre les quatre objectifs du business case : qualité des données, conformité réglementaire (GDPR, CCPA/CPRA, PCI-DSS, réglementations locales), protection de la vie privée, accessibilité et intégration des données entre départements.

Champ d'application. Elle s'applique à tous les employés, prestataires et systèmes qui collectent, stockent, traitent ou partagent des données Spotify, dans les 180+ pays d'opération. Elle couvre les cinq domaines de données et leurs owners :

Domaine	Données	Data Steward	Criticité
User Data	Profils, historiques d'écoute, recherches, playlists, localisation	Steward User	Très haute — GDPR, recommandation
Content	Métadonnées musicales et podcasts (ISRC, artistes, droits)	Steward Content	Haute — recommandation, royalties
Payments	Abonnements, transactions, facturation	Steward Payments	Très haute — PCI-DSS
Ads	Campagnes, ciblage, impressions, segments	Steward Ads	Haute — opt-out CCPA
Marketing	Engagement, segmentation, conversion free → premium	Steward Marketing	Haute — croissance

Définitions. *Donnée personnelle* : toute information relative à une personne identifiable (GDPR art. 4). *Donnée sensible* : catégories de l'art. 9 GDPR, y compris les informations **inférées** (humeur, convictions, santé déduites des écoutes). *Data Owner* : responsable métier d'un domaine. *Data Steward* : garant opérationnel de la qualité et de la conformité d'un domaine. *Traitement* : toute opération sur des données personnelles.

2. Principes (Governance Principles Guide)

#	Principe	Engagement Spotify
1	Accountability	Un owner et un steward nommés par domaine ; RACI publié
2	Transparency	Privacy notice claire par finalité ; consentement granulaire ; information sur durées de conservation et transferts (point sanctionné par l'IMY en 2023)
3	Data Security	Chiffrement, contrôle d'accès par rôle, SIEM, protocole d'incident
4	Data Quality	4 critères mesurés par domaine, audits réguliers
5	Compliance	Revue trimestrielle ; checklist GDPR/CCPA/PCI-DSS tenue à jour (annexe)
6	Data Minimization	Collecte limitée à la finalité ; revue annuelle des datasets et durées de conservation
7	User Rights	Exercice des droits en libre-service et via la Privacy Team, dans les délais légaux
8	Continuous Improvement	Revue annuelle de la politique, retours du Committee et des équipes
9	Ethical Use	Audit des biais de recommandation, explicabilité, pas de profilage sur catégories sensibles inférées

3. Qualité des données

Chaque domaine mesure quatre critères, avec une baseline établie avant toute cible :

Critère	Définition	Cible	Mesure
Complétude	Champs obligatoires renseignés	> 98 %	Great Expectations dans les pipelines
Exactitude	Conformité aux formats et référentiels (ex. ISRC valide)	> 99 %	Great Expectations
Cohérence	Une seule définition par métrique (glossaire métier)	100 % des métriques du glossaire	Catalogue de données
Fraîcheur	Délai production → disponibilité	< 1 h pour les flux temps réel	Observabilité (phase 4)

Les Data Stewards publient les scores mensuellement au Data Governance Committee. Un dataset critique sous la cible deux mois de suite déclenche un plan de remédiation.

4. Sécurité, classification, accès et cycle de vie

Classification (obligatoire pour tout dataset catalogué) :

Classe	Exemples	Protection minimale
Publique	Catalogue musical	Aucune restriction
Interne	Métriques business, rapports	Employés authentifiés
Confidentielle	Historiques d'écoute, profils, segments	Chiffrement au repos et en transit, accès par rôle, pseudonymisation pour l'analytics
Sensible	Paielements, données inférées art. 9, mineurs	Chiffrement renforcé, accès nominatif minimal, journalisation obligatoire, DPIA

Accès et partage. L'accès se demande via le catalogue de données, il est accordé par le Data Steward du domaine selon la classe et le besoin (principe du moindre privilège), et il est revu trimestriellement. Le partage inter-départements se fait sur données **pseudonymisées ou agrégées par défaut** ; l'accès aux données identifiantes exige une finalité documentée. Aucun export de données confidentielles ou sensibles hors des plateformes gouvernées.

Cycle de vie (POSMAD : Plan, Obtain, Store & Share, Maintenir, Apply, Dispose). Chaque dataset a une durée de conservation définie par son steward avec le DPO et inscrite au catalogue. Repères initiaux : logs d'écoute bruts identifiants 13 mois puis agrégation, données de compte pendant la relation contractuelle + délais légaux, données de paiement selon obligations comptables (sans stockage de numéro de carte chez Spotify), données marketing jusqu'au retrait du consentement. À échéance : suppression ou anonymisation irréversible.

Sécurité opérationnelle. Chiffrement systématique des classes Confidentielle et Sensible ; authentification forte ; journalisation centralisée dans le SIEM ; protocole d'incident piloté par le DPO (qualification sous 24 h, notification autorité sous 72 h, information des personnes si risque élevé) ; exercice annuel.

5. Conformité réglementaire

Bases légales par finalité (GDPR art. 6). Fourniture du service et facturation → **contrat** ; recommandation et personnalisation du service → **intérêt légitime ou contrat**, avec option de recommandation non fondée sur le profilage (DSA art. 27) ; publicité ciblée, partage à des tiers, features optionnelles → **consentement** explicite et révocable ; obligations comptables et fiscales → **obligation légale**. Chaque traitement est inscrit au registre des traitements (art. 30) tenu par le DPO.

Droits des personnes.

Droit	Base	Délai	Mise en œuvre
Accès et information (source, destinataires, durées, transferts)	GDPR art. 15, CCPA	1 mois / 45 j	Export libre-service complet ; Privacy Team pour le reste
Rectification	GDPR art. 16, CPRA	1 mois	Paramètres du compte
Effacement	GDPR art. 17, CCPA	1 mois	Pipeline automatisé sur tous les systèmes du domaine
Portabilité	GDPR art. 20	1 mois	Export JSON/CSV
Opposition et limitation	GDPR art. 18, 21	1 mois	Désactivation du profilage publicitaire, gel du traitement
Décision automatisée	GDPR art. 22, DSA art. 27	—	Explicabilité des recommandations, option non profilée
Opt-out de la vente / du partage	CCPA/CPRA	Immédiat	Lien « Do Not Sell or Share », signal GPC honoré
Non-discrimination	CCPA	—	Aucune dégradation de service après exercice d'un droit

Consentement et transparence. Consentement recueilli et tracé par la plateforme de gestion des consentements, granulaire par finalité, aussi simple à retirer qu'à donner. Mineurs : âge minimum par pays, consentement parental (GDPR art. 8), pas de publicité ciblée.

DPIA. Obligatoire avant tout nouveau traitement à risque élevé (nouveau profilage, nouvelle catégorie de données, nouveau transfert), validée par le DPO avant mise en production.

Transferts internationaux. Clauses contractuelles types, EU-US Data Privacy Framework pour les prestataires certifiés, règles d'entreprise contraignantes intra-groupe ; inventaire des transferts au registre.

PCI-DSS. Les données de carte sont traitées par un prestataire de paiement certifié PCI-DSS ; Spotify ne stocke aucun numéro de carte (tokenisation). Obligations conservées par Spotify sur les six exigences de la checklist : réseau et page de paiement sécurisés (SAQ-A annuel), protection des jetons et données de facturation, gestion des vulnérabilités (scans trimestriels, correctifs), contrôle d'accès strict et MFA sur les consoles de paiement, surveillance et tests (SIEM, pentest annuel), politique de sécurité de l'information revue annuellement.

Réglementations locales. CCPA/CPRA (Californie), PDPA (Singapour), LGPD (Brésil, amende jusqu'à 2 % du CA local), DSA (transparence des systèmes de recommandation), AI Act (obligations de transparence pour les systèmes de recommandation). La veille est tenue par le DPO et Legal ; la checklist de conformité (annexe Excel) est mise à jour trimestriellement.

6. Rôles et responsabilités

Les rôles suivent le Data Governance Roles Template ; l'organigramme et les fiches détaillées font l'objet d'un livrable séparé.

- **Chief Data Officer** — porte la stratégie et cette politique, pilote le Centre of Excellence, arbitre les conflits inter-domaines.
- **Data Protection Officer** — indépendant, rattaché à la direction générale ; conformité GDPR/CCPA, DPIA, registre, contact des autorités, pilotage des incidents ; dirige la Privacy Team.
- **Data Governance Committee** (mensuel) — approuve les politiques et standards, traite les sujets inter-départements, suit les KPIs.
- **Data Stewards** (un par domaine) — qualité, classification, accès et conformité de leur domaine.
- **Parties prenantes** — Head of Engineering (implémentation technique des contrôles, sous l'autorité du CTO : la gouvernance définit et audite, l'engineering met en œuvre), Legal (validation juridique), Marketing Director et Product Managers (conformité et privacy by design de leurs périmètres).

RACI des activités clés (A = rend compte, R = réalise, C = consulté, I = informé) :

Activité	CDO	DPO	Head Eng.	Legal	Steward	Engineers	PM / Mktg
Définir et réviser la politique	A/R	C	C	C	C	I	C
Valider un nouveau traitement (DPIA)	I	A/R	C	C	R	I	R
Qualité et classification d'un domaine	I	C	C	I	A/R	R	C
Implémenter contrôles et pipelines	I	C	A/R	I	C	R	I
Traiter les demandes des personnes	I	A	C	C	R	R	I
Gérer un incident de données personnelles	C	A/R	R	C	C	R	I
Auditer les biais de recommandation	C	A	R	C	C	R	C
Former et animer la culture data	A/R	R	C	I	R	I	C

7. Application, exceptions et suivi

Le respect de cette politique est une obligation professionnelle ; les manquements sont traités selon les procédures RH et peuvent entraîner le retrait des accès. Toute exception est demandée par écrit au Data Steward, validée par le CDO (et le DPO si des données personnelles sont concernées), limitée dans le temps et consignée. Le CDO rend compte trimestriellement au comité exécutif des KPIs de gouvernance (qualité, délais de réponse aux droits, incidents, couverture du catalogue, formation). La politique est revue chaque année ; la version 1.0 est déployée d'abord sur le domaine User Data (voir plan d'implémentation).